

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)

Course 3: GRC103 - Risk Assessment and Management Techniques

Lab 3: Advanced GRC Phishing Simulation & Quantitative Risk Analysis

Student Name: Najma Abdi Omar

Reg. No: 2025/GRC/10331

Date: 03/10/2025

PHASE 1: BASIC METRIC CALCULATIONS

Step 1: Calculate Fundamental Rates

Formula: $\text{Rate} = (\text{Number of Events} / \text{Number of Emails Sent}) \times 100^*$

Campaign	Email Open Rate	Click-Through Rate	Credential Submission Rate	Data Entry Rate
A	$(82/100) \times 100$ = 82%	$(47/100) \times 100$ = 47%	$(18/100) \times 100$ = 18%	$(5/100) \times 100$ = 5%
B	$(200/250) \times 100$ = 80%	$(150/250) \times 100$ = 60%	$(75/250) \times 100$ = 30%	$(25/250) \times 100$ = 10%
C	$(72/80) \times 100$ = 90%	$(60/80) \times 100$ = 75%	$(12/80) \times 100$ = 15%	$(8/80) \times 100$ = 10%

Step 2: Calculate Efficiency Metrics

How effective is each step of the attack?

Conversion Rate from Open to Click:

- Campaign A: $(47/82) \times 100$ = **57.3%**
- Campaign B: $(150/200) \times 100$ = **75%**
- Campaign C: $(60/72) \times 100$ = **83%**

Post-Click Credential Submission Rate:

- Campaign A: $(18/47) \times 100$ = **38.3%**
- Campaign B: $(75/150) \times 100$ = **50%**
- Campaign C: $(12/60) \times 100$ = **20%**

PHASE 2: ADVANCED RISK QUANTIFICATION

Step 3: Calculate Organizational Risk Exposure

Scaled Risk Projection:

If these rates apply to our entire organization of 2,000 employees...

For Campaign B (most successful):

- Expected Credentials Stolen: $2,000 \times (75/250) = ?$ **employees**
- Expected Data Breaches: $600 \times 25\%$ probability = ? **breaches**

CALCULATION:

- Campaign B Credential Rate: $75/250 = 30\%$
- Organization Exposure: $2,000 \times 0.30 =$ **600 employees**
- Expected Breaches: $600 \times 0.25 =$ **150 breach incidents**

Step 4: Financial Impact Analysis

A. Calculate Potential Financial Loss:

- Single Breach Cost: \$4,350,000
- Expected Number of Breaches: 150
- Total Exposure: $\$4,350,000 \times 150 =$ **\$652,500,000**

B. Calculate Annualized Loss Expectancy (ALE):

ALE = Single Loss Expectancy $\times$ Annual Rate of Occurrence

- Single Loss Expectancy (SLE): \$4,350,000
- Annual Rate of Occurrence (ARO): 150 expected breaches
- ALE = $\$4,350,000 \times 150 =$ **\$652,500,000**

Step 5: Control Effectiveness Analysis

MFA Cost-Benefit Analysis:

- Cost to Implement MFA: \$45 per user $\times$ 2,000 users = **\$90,000**
- MFA Effectiveness: 99.9% reduction in credential theft impact
- Risk Reduction: $\$652,500,000 \times 0.999 =$ **\$651,847,500**
- ROI: $(\$651,847,500 - \$90,000) / \$90,000 =$ **724,175%**

Security Training Cost-Benefit:

- Training Cost: \$50 per user $\times$ 2,000 users = **\$100,000**

- Expected Effectiveness: 60% reduction in click-through rates
- New Click-Through Rate: $30\% \times (1-0.60) = 12\%$
- New Credentials Stolen: $2,000 \times 0.12 = 240$
- New Expected Breaches: $240 \times 0.25 = 60$
- New ALE: $\$4,350,000 \times 60 = \mathbf{\$261,000,000}$
- Risk Reduction: $\$652,500,000 - \$261,000,000 = \mathbf{\$391,500,000}$
- ROI: $(\$391,500,000 - \$100,000) / \$100,000 = \mathbf{391,400\%}$

PHASE 3: COMPREHENSIVE RISK ASSESSMENT

Step 6: Complete Risk Assessment Matrix

Campaign	Overall Risk Score	Financial Exposure	Priority Level	Recommended Action
A	MEDIUM-HIGH	\$156,600,000	2	Enhanced Training
B	CRITICAL	\$652,500,000	1	IMMEDIATE MFA
C	HIGH	\$104,400,000	2	Executive Training

CALCULATIONS FOR TABLE:

- Campaign A Exposure: $(18/100) \times 2000 = 360$ employees $\times 0.25 \times \$4,350,000 = \$156,600,000$
- Campaign C Exposure: $(12/80) \times 2000 = 300$ employees $\times 0.25 \times \$4,350,000 = \$104,400,000$

Step 7: Statistical Significance Analysis

Calculate Confidence Intervals (95% Confidence):

Formula: $p \pm 1.96 \times \sqrt{p(1-p)/n}$ *

For Campaign B Credential Rate (30%):

- $p = 0.30, n = 250$
- Margin of Error = $1.96 \times \sqrt{0.30(1-0.30)/250} = 1.96 \times \sqrt{0.21/250} = 1.96 \times \sqrt{0.00084} = 1.96 \times 0.029 = 0.057$
- True Rate Range: **24.3% to 35.7%**

YOUR TURN: Calculate for Campaign A:

- $p = 0.18, n = 100$
- Margin of Error = $1.96 \times \sqrt{0.18(1-0.18)/100} = 1.96 \times \sqrt{0.18(0.82)/100} = 1.96 \times \sqrt{0.1476/100} = 1.96 \times \sqrt{0.001476} = 1.96 \times 0.038 = 0.074$
- True Rate Range: $\{(0.18 \pm 0.074) * 100\}$ **10.6% to 25.4%**

PHASE 4: EXECUTIVE REPORTING

Step 8: Comprehensive Executive Briefing

To: Board of Directors, CISO, CFO

From: GRC Risk Analysis Team

Date: 03/10/2025

Subject: CRITICAL: Quantitative Phishing Risk Assessment & \$652M Exposure

1. Executive Summary:

Our phishing simulation analysis reveals a **CRITICAL risk exposure of \$652 million** annually. We have reviewed three phishing campaigns and The "IT Password Reset" campaign, which had the highest rate, showed 30% credential theft rate, projecting to 600 compromised accounts organization-wide. Immediate action is required.

2. Key Quantitative Findings:

Risk Metric	Value	Industry Average	Severity
Overall Credential Theft Rate	22.1%	15.3%	HIGH
Maximum Campaign Success Rate	30%	18.7%	CRITICAL
Annualized Loss Expectancy	\$652M	\$285M	SEVERE
MFA Implementation ROI	724,175%	350%	EXCELLENT

3. Detailed Financial Analysis:

Current State Risk:

- Annualized Loss Expectancy: **\$652,500,000**
- Probability of Major Breach: **93.75%** (150 expected breaches)
- Per-Employee Risk: **\$326,250**

Proposed Security Investment Portfolio:

Based on the numbers presented on analysis of the most successful campaign giving the true standing of our security picture, we realize that the controls proposed have to reflect human centricity and based on that we proposed the below controls showing the cost of the implementation, the risk reduced post control implementation, the net benefit and return on investment, we then prioritized based on the factors and proposed below all centered on reducing human related risks.

Control	Cost	Risk Reduction	Net Benefit	ROI	Priority
MFA Implementation	\$90,000	\$651.8M	\$651.7M	724,175%	1
Enhanced Training	\$100,000	\$391.5M	\$391.4M	391,400%	2
Email Filtering	\$50,000	\$130.5M	\$130.4M	260,800%	3

4. Strategic Recommendations:

IMMEDIATE ACTIONS (Q1):

1. **Implement MFA enterprise-wide** - \$90,000 investment
2. **Launch targeted phishing simulation program** - \$25,000
3. **Conduct emergency security awareness training** - \$100,000

STRATEGIC INITIATIVES (FY2024):

1. **Deploy advanced email security gateway** - \$50,000
2. **Establish continuous security monitoring** - \$150,000
3. **Implement security behavior analytics** - \$75,000

5. Expected Risk Posture After Controls:

Metric	Current	With Controls	Reduction
Credential Theft Rate	22.1%	2.2%	90%
Annual Loss Expectancy	\$652M	\$65M	90%
Breach Probability	93.75%	25%	73.3%

Total Investment Required: \$490,000

Total Risk Reduction: \$587,500,000

Net Financial Benefit: \$587,010,000

BONUS CHALLENGE:

Calculate the break-even point for our security investments. If we invest \$490,000 in controls, how many breaches must we prevent to justify the cost?

Hint: $\$490,000 / \$4,350,000$ per breach = **0.1126 breach**, if I expect 11.26% chance of a single breach then the control cost is justified.